



# Compliance Evidence Pack

Summary Cover Sheet — Sample Pte Ltd

|                 |                          |               |
|-----------------|--------------------------|---------------|
| PDPA COMPLIANCE | DOCUMENTS ANCHORED       | BUNDLE STATUS |
| <b>76/100</b>   | <b>3</b>                 | <b>Active</b> |
| Report ID       | SAMPLE-0001              |               |
| Generated       | 07 Jun 2026 07:42 UTC    |               |
| Bundle          | Compliance Evidence Pack |               |
| Prepared for    | sample@example.com       |               |

■ Bundle Components Delivered

|                                      |                                                                                                                                               |
|--------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|
| PDPA Quick Scan Report               | completed                                                                                                                                     |
| RFP Complete Kit                     | completed                                                                                                                                     |
| Compliance Summary Cover Sheet       | This document — anchored at issue                                                                                                             |
| Signed Cover Sheet (1× notarization) | Awaiting your signature — sign this PDF and upload at <a href="https://booppa.io/compliance/cover-sheet">booppa.io/compliance/cover-sheet</a> |

## ■ PDPA Quick Scan — Full Report

|                     |                                            |
|---------------------|--------------------------------------------|
| Status              | completed                                  |
| Compliance Score    | 76 / 100                                   |
| Scanned URL         | https://example.com                        |
| Risk Level          | Medium                                     |
| Findings            | 6 total — 2 High · 2 Medium · 2 Low        |
| Frameworks Detected | PDPA (Singapore) 2012, PDPA Amendment 2020 |

### Executive Summary

Automated scan of example.com surfaced 6 PDPA-relevant findings: two HIGH (missing breach-notification clause; no published sub-processor list), two MEDIUM (cookie consent granularity; retention schedule), and two LOW (DPO contact published; SAR form present). Remediation focuses on transparency obligations under s. 11, 13, 25, 26 and 26A.

### Detailed Findings (6)

#### 1. Privacy policy missing breach notification clause

HIGH

|                |                                                                                                                                   |
|----------------|-----------------------------------------------------------------------------------------------------------------------------------|
| Description    | Privacy policy does not specify the 72-hour PDPC notification timeline for notifiable data breaches.                              |
| Legislation    | PDPA s. 26A-26E — Data Breach Notification Obligation                                                                             |
| Evidence       | Privacy page does not mention 'notifiable data breach' or 72-hour PDPC notification window.                                       |
| Recommendation | Add a Breach Notification section to the privacy policy stating the 72-hour PDPC notification commitment for notifiable breaches. |

#### 2. DPO contact published

LOW

|                |                                                                    |
|----------------|--------------------------------------------------------------------|
| Description    | Dedicated DPO email on Privacy page satisfies PDPA accountability. |
| Legislation    | PDPA s. 11 — Accountability Obligation                             |
| Evidence       | Privacy page: dpo@example.com                                      |
| Recommendation | Add an SLA for DPO response time on the same page.                 |

#### 3. Cookie consent banner present but lacks granular toggles

MEDIUM

|                |                                                                                                              |
|----------------|--------------------------------------------------------------------------------------------------------------|
| Description    | Site shows a single accept/reject banner; PDPA-aligned but not granular for analytics vs. marketing cookies. |
| Legislation    | PDPA s. 13 — Consent Obligation                                                                              |
| Evidence       | https://example.com/ — first-visit banner; one accept + one reject button.                                   |
| Recommendation | Add per-category toggles (Essential / Analytics / Marketing) and persist the buyer's choice for 365 days.    |

#### 4. No published data retention schedule

MEDIUM

|                |                                                                                                                                     |
|----------------|-------------------------------------------------------------------------------------------------------------------------------------|
| Description    | Privacy policy mentions retention 'as long as necessary' without per-category timeframes.                                           |
| Legislation    | PDPA s. 25 — Retention Limitation Obligation                                                                                        |
| Evidence       | Privacy page — 'Retention' section uses 'as long as necessary' without categorical limits.                                          |
| Recommendation | Publish a retention schedule by data category (e.g. account data: 7 years post-closure; marketing: 24 months from last engagement). |

**5. Subject Access Request (SAR) form provided**

LOW

|                |                                                                                                                                     |
|----------------|-------------------------------------------------------------------------------------------------------------------------------------|
| Description    | SAR submission form available at /privacy/sar with email + identity verification.                                                   |
| Legislation    | PDPA s. 21 — Access & Correction Obligation                                                                                         |
| Evidence       | <a href="https://example.com/privacy/sar">https://example.com/privacy/sar</a> — form present, identity verification step described. |
| Recommendation | Publish the 30-day SAR response SLA on the same page so requesters know the timeline.                                               |

**6. No published list of overseas sub-processors**

HIGH

|                |                                                                                                                                                      |
|----------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| Description    | Privacy policy mentions 'cloud providers' generically without naming them; PDPA s. 26 requires comparable protection for overseas transfers.         |
| Legislation    | PDPA s. 26 — Transfer Limitation Obligation                                                                                                          |
| Evidence       | Privacy page — no Sub-processors / Third-party processors section enumerating named vendors.                                                         |
| Recommendation | Publish a Sub-processors page listing named vendors, processing purpose, hosting region, and the safeguard relied on (SCCs / equivalent protection). |

## ■ RFP Complete Kit — Full Q&A

|                  |                       |
|------------------|-----------------------|
| Status           | completed             |
| Product          | Rfp Complete          |
| Q&A Coverage     | 15 questions answered |
| Answer Source    | Ai Grounded           |
| Generated        | 07 Jun 2026 07:42 U   |
| Bid Kit Download | Available — see email |

### Executive Summary

RFP Complete Kit covers 15 PDPA, ISO, encryption, residency, sub-processor, BCP/DR, and breach-history questions. 11 of 15 answers verified against intake or website signals; 4 are AI-drafted from policy defaults and flagged for buyer review.

### RFP Q&A (15)

#### Q1. Are personal data stored at rest using AES-256 or stronger encryption?

INTAKE + WEBSITE

Yes — at-rest encryption is enabled across all production databases using AWS KMS with AES-256 keys. Daily snapshots inherit the same key.

Evidence: S · e · c · u

#### Q2. What is the bidder's data residency for personal data in scope?

FROM YOUR INTAKE

Singapore residency — all production data is hosted in AWS ap-southeast-1 (Singapore region). No personal data is replicated outside the SG region.

Evidence: C · o · n · f

#### Q3. Is the bidder ISO/IEC 27001 certified?

FROM YOUR INTAKE

Yes — ISO/IEC 27001:2022 certified, certificate IS-7XX-22 issued by BSI, valid through 2027-04-30.

Evidence: I · n · t · a

#### Q4. Has the bidder appointed a Data Protection Officer (DPO)?

INTAKE + WEBSITE

Yes — a DPO is appointed and contactable at dpo@example.com. The DPO reports to the CEO and reviews policy changes quarterly.

Evidence: P · r · i · v

#### Q5. Does the bidder maintain a Business Continuity / Disaster Recovery plan?

FROM YOUR INTAKE

Yes — RTO is 4 hours, RPO is 15 minutes. The plan is tested twice yearly with live failover to a secondary AZ in the same region.

Evidence: I · n · t · a

#### Q6. What encryption is used for data in transit?

VERIFIED ON YOUR WEBSITE

TLS 1.2 minimum across all external surfaces; internal service-to-service traffic uses mTLS within the VPC.

Evidence: S · S · L ·

#### Q7. Has the bidder experienced any notifiable data breaches in the past 24 months?

FROM YOUR INTAKE

No — no notifiable data breaches under PDPA s. 26A in the past 24 months.

Evidence: I · n · t · a

**Q8. What are the bidder's published sub-processors?**

FROM YOUR INTAKE

AWS (hosting, Singapore region), Stripe (payments, US-hosted with SCCs), Resend (transactional email, EU-hosted with SCCs).

*Evidence: I · n · t · a*

**Q9. How frequently is staff trained on PDPA / data-protection obligations?**

FROM YOUR INTAKE

Annually for all staff, with a quarterly micro-module for staff handling personal data directly.

*Evidence: I · n · t · a*

**Q10. What is the bidder's SAR (Subject Access Request) response SLA?**

AI DRAFT — REVIEW

30 days from receipt of a valid request, in line with PDPC guidance.

*Evidence: N · o · i*

**Q11. Does the bidder run regular penetration tests?**

AI DRAFT — REVIEW

Yes — third-party penetration test annually; remediation report shared with enterprise customers under NDA.

*Evidence: C · o · m · m*

**Q12. What's the bidder's policy on retention of personal data?**

AI DRAFT — REVIEW

Account data retained for 7 years after closure (tax / dispute window); marketing engagement data retained 24 months from last interaction; logs retained 90 days.

*Evidence: D · e · r · i*

**Q13. Does the bidder have a documented incident response plan?**

AI DRAFT — REVIEW

Yes — IR plan with on-call rotation, severity tiers, and a 72-hour PDPC notification track for notifiable breaches.

*Evidence: A · I · i · g*

**Q14. Is the bidder a Singapore-registered entity?**

EXTERNAL EVIDENCE

Yes — Sample Pte Ltd, UEN 202506025X, ACRA-registered.

*Evidence: A · C · R · A*

**Q15. What's the bidder's MAS TRM posture (if applicable)?**

AI DRAFT — REVIEW

Self-attested alignment with MAS TRM Guidelines (Jun-2021 revision) across the 13 domains; full gap analysis available under NDA.

*Evidence: S · e · l · f*



## ■ Risk Overview

---

This pack represents a snapshot assessment. Booppa's automated scans cover PDPA obligations and vendor credibility signals. A qualified DPO should review findings before submission to regulators.

## ■ Recommendations

---

1. Publish a Subject Access Request (SAR) policy with a 30-day response SLA.
2. Add granular cookie consent toggles for analytics vs. marketing.
3. Document Sub-processor list with quarterly review cadence.

## ■ Legal Disclaimer

---

This document is generated by Booppa Smart Care LLC (UEN: 202506025W) for informational purposes only. It does not constitute legal advice. The blockchain anchors provide evidence of document existence at a point in time but do not guarantee regulatory compliance. © Booppa Smart Care LLC. All rights reserved.